

ONEDRAFT

CAD-AI — Aria Powered

API Gateway, Rate Limiting & Service Protection Architecture

Version 1.0

Document: OneDraft API Gateway, Rate Limiting & Service Protection Architecture Specification

System: OneDraft CAD-AI

Intelligence Layer: Aria

Document Class: Architectural & Implementation Stack Specification

Status: Architectural Specification

Predecessor: Multi-Tenant Organization & Project Isolation Architecture Specification

Successor: Performance, Scalability & Capacity Architecture Specification

1. PURPOSE

The API Gateway, Rate Limiting & Service Protection Architecture establishes the controlled request boundary through which external clients, frontend applications, integrations and internal services communicate with OneDraft.

The purpose of this subsystem is to provide centralized request admission, routing, authentication integration, authorization enforcement, rate limiting, quota enforcement, abuse protection, request validation, traffic control and service protection.

The API gateway shall provide a controlled boundary between request sources and the internal OneDraft service architecture.

2. ARCHITECTURAL ROLE

The API Gateway forms the primary request-control layer of OneDraft.

It connects external and internal request sources to the application, domain, runtime, AI, computational, artifact and administrative services.

Primary responsibility: Admit, validate, protect, route and observe requests.

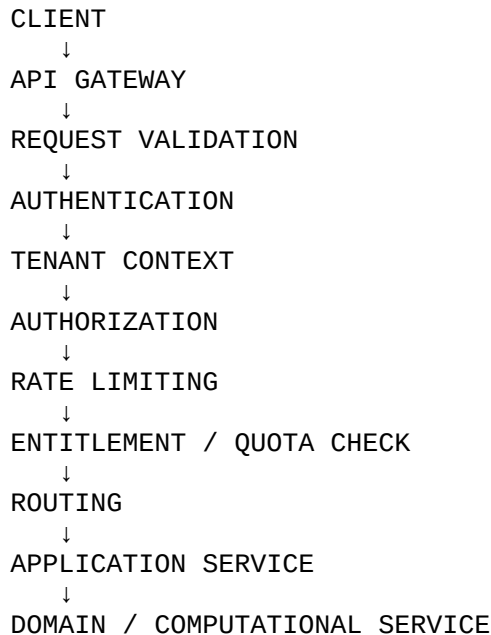
Primary inputs: HTTP requests, API credentials, authenticated sessions, service credentials, tenant context and request metadata.

Primary outputs: Authorized service requests, rate-limit decisions, routing decisions, structured errors, telemetry and request records.

Authority: The gateway shall enforce request-level controls while downstream services remain authoritative for domain operations and business rules.

3. GATEWAY ARCHITECTURE

The canonical request path shall follow:



The gateway shall not replace application authorization, domain validation or lifecycle controls.

4. REQUEST SOURCES

OneDraft shall support controlled request sources including:

Web Frontend

Mobile or Future Clients

Public API Clients

Organization Integrations

SDK Clients

Administrative Clients

Internal Services

Worker Services

Each request source shall use the authentication and authorization mechanism appropriate to its trust level.

5. API BOUNDARY

The gateway shall provide a stable external API boundary.

External clients shall not directly access internal service endpoints unless explicitly authorized through an internal service architecture.

Internal implementation details shall remain separated from public API contracts.

6. API VERSIONING

Public APIs shall be versioned.

A representative structure may include:

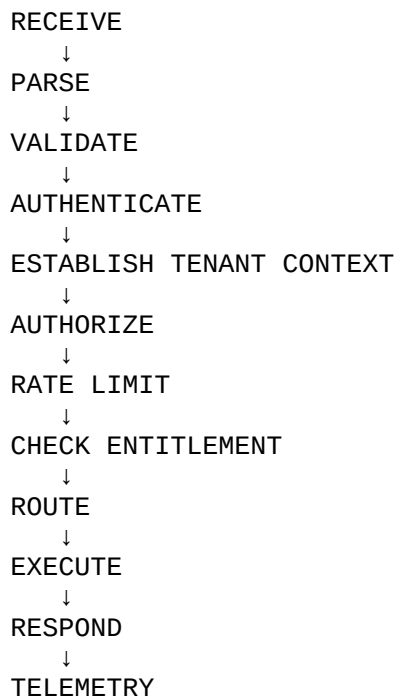
`/api/v1/...`

Major API versions shall define explicit compatibility boundaries.

Breaking changes shall require a new major API version or an equivalent controlled versioning mechanism.

7. REQUEST LIFECYCLE

Every API request shall pass through a defined request lifecycle.



Failed requests shall terminate at the earliest appropriate control boundary.

8. REQUEST IDENTIFICATION

Each request shall receive a unique request identifier.

The identifier shall be propagated through applicable application services, workers, events and telemetry.

Request identifiers shall support:

Tracing

Debugging

Audit Correlation

Error Investigation

Operational Analysis

9. CORRELATION IDENTIFIERS

Requests participating in a larger workflow shall support correlation identifiers.

A correlation identifier may connect:

API Request

Aria Command

Job

Worker Execution

Event

Artifact Generation

Validation

Drawing Generation

This enables end-to-end operational tracing.

10. REQUEST VALIDATION

The gateway shall perform structural request validation before routing requests to application services.

Validation may include:

HTTP Method

Path

Headers

Content Type

Payload Size

Schema

Required Parameters

Encoding

Malformed requests shall be rejected before entering the application layer.

11. OPENAPI CONTRACT

Public API behavior shall be defined through the OneDraft OpenAPI contract.

The gateway shall enforce or support:

Endpoint Definitions

Request Schemas

Response Schemas

Authentication Schemes

Error Structures

Versioning

Content Types

The gateway contract shall remain synchronized with application implementation.

12. AUTHENTICATION INTEGRATION

The gateway shall integrate with the OneDraft Identity and Access architecture.

Authentication may use:

Session Authentication

OAuth/OIDC

API Keys

Service Credentials

Signed Tokens

The selected mechanism shall depend upon the request source.

Authentication establishes identity but does not independently establish authorization.

13. AUTHORIZATION INTEGRATION

Authorization shall be evaluated using the OneDraft authorization architecture.

The gateway shall establish sufficient context for downstream authorization.

Authorization shall consider:

User

Organization

Project

Role

Permission

Resource

Operation

The gateway shall not infer authorization solely from a valid authentication token.

14. TENANT CONTEXT

Every tenant-aware request shall establish organization context before reaching protected application services.

The gateway shall propagate:

Organization Identifier

User Identifier

Project Identifier, where available.

Membership Context

Authorization Context

The downstream service shall independently verify sensitive resource access.

15. SERVICE-TO-SERVICE AUTHENTICATION

Internal services shall authenticate to one another using controlled service identities.

Internal requests may contain:

Service Identity

Request Identity

Organization Context

Project Context

Correlation Identifier

Internal authentication shall prevent an external user from impersonating an internal service.

16. ROUTING

The gateway shall route requests according to explicit service boundaries.

Representative routes include:

```
/api/v1/projects  
/api/v1/models  
/api/v1/validation  
/api/v1/compliance  
/api/v1/drawings  
/api/v1/reviews  
/api/v1/aria  
/api/v1/jobs  
/api/v1/artifacts  
/api/v1/billing  
/api/v1/organizations
```

Routing shall remain independent from frontend implementation details.

17. SERVICE DISCOVERY

Internal routing may use service discovery mechanisms appropriate to the deployment environment.

The gateway shall not hard-code unstable infrastructure addresses where dynamic service discovery is available.

Service endpoints shall be configurable through the infrastructure and configuration architectures.

18. RATE LIMITING

Rate limiting shall control request frequency.

Rate limits may apply to:

User

Organization

API Key

IP Address

Endpoint

Service

Project

Subscription

Rate-limit configuration shall remain versioned and administratively controlled.

19. RATE-LIMITING ALGORITHM

The implementation may use mechanisms such as:

Token Bucket

Leaky Bucket

Sliding Window

Fixed Window

The selected mechanism shall support the required traffic profile and operational guarantees.

The exact implementation shall remain an infrastructure-level decision provided that externally observable behavior satisfies the defined API contract.

20. RATE-LIMIT KEYS

Rate-limit keys shall be scoped appropriately.

Examples include:

```
user:{user_id}  
organization:{organization_id}  
api_key:{key_id}  
endpoint:{route}
```

Composite keys may be used where multiple dimensions must be enforced simultaneously.

Tenant-aware limits shall not use global identifiers that could cause one organization's traffic to affect another organization's quota unless explicitly intended.

21. BURST CONTROL

Rate limiting shall support controlled traffic bursts.

Burst capacity may permit short-term increases above the sustained rate while maintaining a defined average throughput.

Burst behavior shall be documented for API consumers.

22. CONCURRENCY LIMITS

Some operations shall require concurrency limits rather than request-frequency limits.

Examples include:

Geometry Computation

Large Model Regeneration

Drawing Generation

Rendering

Bulk Export

AI Processing

Concurrency limits shall protect workers and computational resources.

23. REQUEST SIZE LIMITS

The gateway shall enforce request-size limits.

Limits shall apply to:

JSON Payloads

Multipart Uploads

Imported CAD Files

BIM Files

Images

PDFs

Large files shall use controlled artifact-upload mechanisms rather than unrestricted API payloads where appropriate.

24. TIMEOUTS

Gateway and service timeouts shall be explicitly configured.

Timeout classes may include:

Standard API

Interactive API

AI Request

File Upload

File Download

Long-Running Job Submission

Long-running operations shall normally be represented by asynchronous jobs rather than extended synchronous requests.

25. LONG-RUNNING OPERATIONS

Operations such as geometry regeneration, large drawing packages and extensive compliance analysis shall use asynchronous execution where appropriate.

The API shall return a job reference.

```
POST /operation
  ↓
JOB CREATED
  ↓
202 ACCEPTED
  ↓
GET /jobs/{job_id}
```

The worker system shall perform the operation independently of the original HTTP request.

26. IDEMPOTENCY

Mutating API operations shall support idempotency where repeated requests could create duplicate effects.

Examples include:

Project Creation

Job Submission

Payment-Related Operations

Artifact Creation

Export Requests

An idempotency key shall identify logically identical requests.

27. RETRY SAFETY

The gateway and clients shall distinguish retry-safe operations from non-idempotent operations.

The gateway shall not blindly retry requests that could create duplicate domain effects.

Retry behavior shall be coordinated with application services and job execution.

28. ERROR HANDLING

The API shall return structured error responses.

A canonical error structure shall contain:

Error Code

Message

Request Identifier

Correlation Identifier

Details, where appropriate.

Errors shall distinguish:

Authentication Failure

Authorization Failure

Validation Failure

Rate Limit

Quota

Not Found

Conflict

Service Unavailable

Internal Failure

29. RATE-LIMIT RESPONSE

When a request is rate-limited, the API shall provide an appropriate structured response.

The response may include:

HTTP 429

Error Code

Retry Information

Request Identifier

Rate-limit responses shall not expose internal infrastructure details.

30. ENTITLEMENT INTEGRATION

The gateway shall integrate with the Billing, Subscription & Entitlement architecture.

Before protected commercial capabilities are invoked, the applicable entitlement may be evaluated.

Examples include:

AI Access

CAD Export

BIM Export

Advanced Validation

Large Computation

API Access

The gateway shall enforce coarse-grained commercial access while application services enforce domain-specific conditions.

31. QUOTA INTEGRATION

Quota checks shall be performed where request admission depends upon available organizational capacity.

The gateway may perform fast quota checks while authoritative usage accounting remains within the billing and usage architecture.

Quota exhaustion shall result in a deterministic response.

32. ABUSE PROTECTION

The gateway shall provide controls against abusive request patterns.

Controls may include:

Rate Limiting

Burst Control

Concurrency Limits

Payload Limits

Authentication Requirements

IP Reputation Controls

Request Pattern Detection

Automated Blocking

These controls shall be configurable and observable.

33. BOT AND AUTOMATION CONTROL

Public-facing endpoints may require additional controls against automated abuse.

Controls may include:

API Credentials

Session Validation

Challenge Mechanisms

Request Limits

Behavioral Controls

The platform shall avoid imposing unnecessary controls on legitimate automated integrations.

34. IP CONTROLS

Where required, OneDraft may support:

IP Allow Lists

IP Deny Lists

Organization Network Restrictions

Administrative Access Restrictions

IP controls shall supplement identity-based authorization rather than replace it.

35. CORS

Browser-based API access shall use explicit Cross-Origin Resource Sharing policies.

Allowed origins shall be controlled by environment and application configuration.

Wildcard origins shall not be used for authenticated administrative operations unless explicitly justified.

36. CSRF PROTECTION

Browser-based authenticated operations shall implement appropriate CSRF protection where session-based authentication is used.

Token-based API authentication shall use the applicable security model.

CSRF controls shall remain coordinated with the frontend authentication architecture.

37. HEADER SECURITY

The gateway shall establish appropriate security headers.

Headers may address:

Content Security

Frame Restrictions

Content Type Handling

Transport Security

Referrer Policy

Browser Feature Restrictions

The exact policy shall be established through the security architecture.

38. TLS

External API communication shall use encrypted transport.

Production endpoints shall require current secure TLS configuration.

Internal service communication shall use encrypted transport where deployment topology and threat model require it.

Certificates shall be managed through the infrastructure and secrets architecture.

39. WAF INTEGRATION

OneDraft may deploy a Web Application Firewall in front of the API gateway.

The WAF may provide:

Common Attack Detection

Request Filtering

Protocol Enforcement

Bot Protection

Traffic Controls

The WAF shall complement rather than replace application security controls.

40. REQUEST LOGGING

The gateway shall produce structured request telemetry.

Records may include:

Request Identifier

Timestamp

Method

Route

Status

Latency

Organization

User

Service

Rate-Limit Result

Sensitive request payloads shall not be logged by default.

41. SENSITIVE DATA PROTECTION

Gateway logging shall prevent unnecessary exposure of:

Passwords

Tokens

API Keys

Payment Credentials

Private Project Data

AI Context

Sensitive Files

Sensitive headers and payload fields shall be redacted or excluded.

42. OBSERVABILITY

The gateway shall integrate with OneDraft observability.

Metrics shall include:

Request Rate

Error Rate

Latency

Throughput

Rate-Limit Events

Authentication Failures

Authorization Failures

Timeouts

Upstream Failures

Gateway Availability

Distributed traces shall preserve request and correlation identifiers.

43. HEALTH MANAGEMENT

The gateway shall monitor downstream service health.

Health states may include:

HEALTHY

DEGRADED

UNAVAILABLE

Routing behavior may adapt according to service availability.

The gateway shall not route traffic to unavailable service instances where service discovery supports health-aware routing.

44. CIRCUIT BREAKING

The gateway or service mesh may use circuit breakers to prevent repeated requests to failing services.

Circuit states may include:

CLOSED

OPEN

HALF_OPEN

Circuit breaking shall reduce cascading failures.

45. LOAD SHEDDING

Where service capacity is constrained, the platform may reject lower-priority or excess traffic to preserve core system availability.

Load shedding shall be deterministic and observable.

Critical operations shall receive appropriate priority according to platform policy.

46. PRIORITY MANAGEMENT

Requests may receive priority classifications.

Potential priority levels include:

INTERACTIVE

STANDARD

BACKGROUND

ADMINISTRATIVE

SYSTEM_CRITICAL

Priority controls shall be applied carefully to prevent starvation of ordinary tenant workloads.

47. MULTI-TENANT PROTECTION

Rate limiting, concurrency and capacity controls shall respect tenant boundaries.

One organization's workload shall not unintentionally consume all shared capacity.

Organization-level limits shall integrate with subscription entitlements and platform capacity controls.

The gateway shall support fair resource allocation.

48. SECURITY, TESTING & ARCHITECTURAL INVARIANTS

The API Gateway shall be tested against:

Authentication Bypass

Authorization Bypass

Cross-Tenant Access

Rate-Limit Bypass

Quota Bypass

Payload Abuse

Request Smuggling

Malformed Requests

Replay Attempts

Idempotency Failures

Timeouts

Service Failures

Concurrent Requests

Load Conditions

The following invariants shall govern the subsystem.

Backend Authority: Gateway controls shall not replace domain authorization.

Default Denial: Protected endpoints shall require explicit authorization.

Tenant Isolation: Requests shall retain tenant context throughout execution.

Rate Enforcement: Defined limits shall be enforced server-side.

Idempotency: Retryable mutations shall not produce uncontrolled duplicate effects.

No Credential Logging: Sensitive credentials shall not be exposed through telemetry.

Long-Running Separation: Long-running workloads shall use asynchronous execution where appropriate.

Service Protection: Failure of one subsystem shall not automatically cascade across the platform.

Observability: Every request shall be traceable through a request or correlation identifier.

API Stability: Public contracts shall remain versioned and controlled.

49. IMPLEMENTATION REQUIREMENTS

The implementation shall provide:

API Gateway Service

Authentication Middleware

Tenant Context Middleware

Authorization Middleware

Rate-Limit Service

Quota Integration

Request Validation

Routing Layer

Error Handling

Request Telemetry

Security Middleware

Health Checking

Circuit Breaking

Service Discovery Integration

API Version Management

The gateway shall integrate with PostgreSQL, Redis, the event bus, worker system, identity system, billing system and observability platform according to the established OneDraft architecture.

50. COMPLETION STATUS

The API Gateway, Rate Limiting & Service Protection Architecture establishes the controlled request boundary for OneDraft.

The subsystem defines API versioning, request validation, authentication, authorization integration, tenant context, routing, rate limiting, concurrency limits, payload protection, timeouts, asynchronous operations, idempotency, error handling, entitlement and quota integration, abuse protection, CORS, CSRF, TLS, WAF integration, observability, health management, circuit breaking, load shedding, priority management and multi-tenant service protection.

The architecture provides the request-admission and protection layer required for OneDraft to operate reliably as a multi-tenant CAD-AI platform.

The next architectural layer establishes the Performance, Scalability & Capacity Architecture, defining how OneDraft accommodates geometry workloads, concurrent projects, queue scaling, database growth, computational demand and production capacity.

Status: ARCHITECTURALLY DEFINED

Next Document: Performance, Scalability & Capacity Architecture Specification

Overall Architecture: OneDraft End-to-End System Integration